

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking

COURSE CODE: ITA1407

COURSE OUTCOME COVERED

CO4: Implement network security testing methods by performing web server attacks, analyzing web application vulnerabilities, and assessing wireless network security using Kali Linux.

1. TJX Companies Wireless Network Breach, 2005–2007

TJX Companies experienced a major payment-card data breach after attackers obtained unauthorized wireless access to its retail network. Investigations found that TJX had used WEP while transitioning to WPA and had not implemented adequate controls to restrict wireless access. The incident demonstrated the risks of obsolete encryption, inadequate monitoring, weak network segmentation, and insecure transmission of sensitive data.

Assignment Question: Prepare a Vulnerability Assessment Report examining the wireless encryption, authentication, network segmentation, monitoring, and payment-data protection weaknesses that contributed to the TJX incident. Recommend how WPA2/WPA3, enterprise authentication, rogue-access-point detection, and PCI DSS controls could have reduced the risk.

Answer:

1. Incident Background and Technical Understanding

TJX Companies suffered a major payment-card data breach after attackers gained unauthorized access to its wireless network. The company was using WEP encryption, which provided weak wireless security.

Attackers exploited weaknesses in the wireless network and gained access to systems containing sensitive customer and payment-card information.

Attack flow

Weak WEP Wireless Network → Unauthorized Access → Internal Network Access → Sensitive Data Exposure → Payment-Card Data Theft

2. Identification of Wireless Vulnerabilities

Vulnerability	Severity
WEP encryption	Critical
Weak wireless authentication	High
Poor network segmentation	High
Inadequate monitoring	High
Sensitive data insufficiently protected	Critical
Unauthorized wireless access	High

3. Risk, Impact and Root Cause

Root causes

- Continued use of weak WEP encryption.
- Insufficient wireless access controls.
- Poor separation between wireless and sensitive internal systems.
- Inadequate monitoring of wireless activity.

Impact

- Payment-card information exposure.
- Customer privacy risks.
- Financial losses.
- Legal and regulatory consequences.
- Damage to company reputation.

Overall risk: Critical

4. Security Recommendations

- Replace WEP with WPA2-Enterprise/WPA3-Enterprise.
- Implement 802.1X authentication.
- Separate wireless networks using VLANs.
- Apply strong firewall and access-control rules.
- Encrypt sensitive payment data.
- Deploy wireless intrusion detection.
- Continuously monitor wireless traffic.
- Follow PCI DSS requirements.
- Regularly perform wireless security assessments.

5. Conclusion

The TJX incident demonstrates that weak wireless encryption and inadequate network segmentation can allow attackers to reach sensitive corporate systems. Strong encryption, enterprise authentication, segmentation and continuous monitoring are essential.

2. Lowe's Wireless Network Intrusion, 2003

In 2003, attackers compromised the wireless network of a Lowe's retail store in Southfield, Michigan. The compromised wireless connection provided access to the company's central systems and other retail locations. The attackers attempted to install software intended to capture customers' credit-card information.

Assignment Question: Prepare a Vulnerability Assessment Report identifying the weaknesses that allowed a local wireless compromise to create access to a nationwide corporate network. Assess authentication, wireless isolation, firewall controls, point-of-sale segmentation, intrusion detection, and centralized access management.

Answer:

1. Incident Background and Technical Understanding

Lowe's experienced a wireless network intrusion in which attackers compromised a wireless connection at a retail store. The compromised network provided access toward the company's internal systems.

The attackers attempted to install software designed to capture customer credit-card information.

Attack flow

Weak Wireless Security → Unauthorized Wireless Access → Internal Network Access → Malware Installation Attempt → Credit-Card Data Risk

2. Identification of Wireless Vulnerabilities

Vulnerability	Severity
Weak wireless authentication	High
Insufficient wireless isolation	High
Poor firewall controls	High
Inadequate POS segmentation	Critical
Insufficient intrusion detection	High
Unauthorized device access	High

3. Risk, Impact and Root Cause

Root causes

- Weak wireless security configuration.
- Insufficient isolation of wireless networks.
- Inadequate firewall restrictions.
- Poor separation of wireless systems from point-of-sale systems.

Impact

- Unauthorized access to internal resources.
- Possible credit-card information theft.
- Malware installation.
- Financial and reputational damage.

Overall risk: Critical

4. Security Recommendations

- Use WPA2/WPA3 Enterprise.
- Implement 802.1X authentication.
- Isolate guest wireless networks.
- Place POS systems in a separate secure VLAN.
- Use firewalls between wireless and internal networks.
- Deploy IDS/IPS.
- Restrict access using least privilege.
- Monitor unauthorized devices.

5. Conclusion

The Lowe's incident shows that wireless networks should never provide unrestricted access to sensitive internal systems. Strong authentication, network isolation and POS segmentation can significantly reduce the risk.

3. Firesheep and Public Wi-Fi Session Hijacking, 2010

The Firesheep browser extension demonstrated how attackers connected to the same open wireless network could capture unencrypted session cookies and impersonate authenticated users. The event highlighted the danger of websites encrypting only the login page while transmitting later session information without full HTTPS protection.

Assignment Question: Prepare a Vulnerability Assessment Report for a public Wi-Fi provider affected by Firesheep-style session hijacking. Assess open-network authentication, session-cookie protection, HTTPS enforcement, HSTS, VPN use, wireless client isolation, and user-security awareness.

Answer:

1. Incident Background and Technical Understanding

Firesheep was a browser extension that demonstrated how session cookies could be captured on open public Wi-Fi networks. Websites that protected only the login process but did not use HTTPS consistently could expose authenticated sessions.

An attacker connected to the same open wireless network could potentially capture unencrypted session information and impersonate users.

Attack flow

Open Wi-Fi → Unencrypted HTTP Traffic → Session Cookie Exposure → Session Hijacking → Unauthorized Account Access

2. Identification of Wireless Vulnerabilities

Vulnerability	Severity
Open public Wi-Fi	High
Unencrypted HTTP traffic	Critical
Insecure session cookies	High
Lack of HTTPS enforcement	Critical
Insufficient client isolation	Medium
Poor user awareness	Medium

3. Risk, Impact and Root Cause

Root causes

- Websites did not consistently use HTTPS.
- Session cookies could be transmitted without sufficient protection.
- Public Wi-Fi allowed nearby users to observe network traffic.

Impact

- Session hijacking.
- Unauthorized account access.
- Privacy loss.
- Possible exposure of personal information.

4. Security Recommendations

- Enforce HTTPS across the entire website.
- Enable HSTS.
- Use Secure and HttpOnly cookie attributes.
- Use SameSite cookie protection where appropriate.
- Regenerate session IDs after authentication.
- Use VPN on untrusted public Wi-Fi.
- Enable client isolation on public wireless networks.
- Educate users about public Wi-Fi risks.

5. Conclusion

The Firesheep example demonstrated the danger of using unencrypted services over public Wi-Fi. Full HTTPS, secure session management and VPN usage significantly reduce session-hijacking risks.

4. DarkHotel Attacks Through Hotel Wi-Fi Networks

The DarkHotel campaign targeted business executives and government officials using compromised hotel networks. Selected guests connecting to hotel Wi-Fi were presented with fraudulent software-update prompts that delivered malware. The campaign demonstrated the risks associated with third-party Wi-Fi management, captive portals, insecure update mechanisms, and insufficient guest-network monitoring.

Assignment Question: Prepare a Vulnerability Assessment Report for the affected hotel environment. Examine guest authentication, captive-portal security, DNS integrity, network segmentation, third-party access, digital-signature verification, malware detection, and monitoring of privileged hotel-network systems.

Answer:

1. Incident Background and Technical Understanding

The DarkHotel campaign targeted business executives and government officials using hotel Wi-Fi networks. Attackers abused weaknesses in hotel network infrastructure and used fraudulent software-update mechanisms to deliver malware.

The attack demonstrated the risks associated with hotel Wi-Fi, captive portals, third-party services and insecure software-update processes.

Attack flow

Hotel Wi-Fi → User Connection → Fraudulent Update Prompt → Malware Installation → Credential/Data Compromise

2. Identification of Wireless Vulnerabilities

Vulnerability	Severity
Untrusted hotel Wi-Fi	High
Fraudulent software updates	Critical
Weak update verification	Critical
Captive-portal weaknesses	High
Insufficient network monitoring	High
Third-party infrastructure risk	High

3. Risk, Impact and Root Cause

Root causes

- Users trusted hotel Wi-Fi environments.
- Software-update mechanisms were not sufficiently protected.
- Attackers exploited trusted relationships and infrastructure.
- Insufficient monitoring of suspicious network activity.

Impact

- Malware infection.
- Credential theft.
- Corporate information exposure.
- Targeted espionage.
- Financial and reputational damage.

Overall risk: Critical

4. Security Recommendations

- Use VPN on hotel/public Wi-Fi.
- Require digitally signed software updates.
- Verify software-update certificates.
- Enable endpoint protection.
- Use MFA for important accounts.
- Segment hotel guest networks.

- Monitor wireless infrastructure.
- Use secure DNS and web filtering.
- Train employees to reject unexpected update prompts.

5. Conclusion

The DarkHotel case demonstrates that attackers can exploit users' trust in hotel networks and software updates. Strong endpoint security, VPNs, MFA and verified software updates are essential.

5. Marriott Wi-Fi Deauthentication Incident, 2014

The United States Federal Communications Commission investigated Marriott after equipment was used to send Wi-Fi deauthentication messages that prevented guests from using their personal hotspots. Marriott agreed to pay a civil penalty of \$600,000. The incident showed how unprotected wireless management frames could be misused to disconnect legitimate users.

Assignment Question: Prepare a Vulnerability Assessment Report analysing the misuse of IEEE 802.11 deauthentication frames. Discuss availability risks, wireless interference, Protected Management Frames, WPA3 requirements, wireless intrusion detection, acceptable-use policies, and legal consequences.

Answer:

1. Incident Background and Technical Understanding

In 2014, the U.S. Federal Communications Commission investigated Marriott after equipment was used to send Wi-Fi deauthentication messages that interfered with guests' personal hotspots.

The incident demonstrated that wireless management frames can be abused to disrupt legitimate wireless connections.

Attack flow

Wireless Environment → Deauthentication Frames → Client Disconnection → Loss of Connectivity → Availability Impact

2. Identification of Wireless Vulnerabilities

Vulnerability	Severity
Unprotected management frames	High
Deauthentication-frame abuse	High
Insufficient wireless monitoring	High
Lack of protected management frames	High
Weak acceptable-use controls	Medium

3. Risk, Impact and Root Cause

Root causes

- Wireless management frames were not adequately protected.
- Insufficient monitoring of abnormal wireless activity.
- Lack of appropriate controls against unauthorized interference.

Impact

- Legitimate users can be disconnected.
- Loss of network availability.
- Business disruption.
- Potential financial losses.
- Legal and regulatory consequences.

Overall risk: High

4. Security Recommendations

- Enable Protected Management Frames (PMF / 802.11w) where supported.
- Use WPA2/WPA3 security.
- Deploy wireless intrusion detection/prevention.
- Monitor abnormal deauthentication activity.
- Establish clear acceptable-use policies.
- Restrict wireless management access.
- Regularly audit wireless infrastructure.
- Maintain incident-response procedures.

5. Conclusion

The Marriott incident demonstrates that wireless security is not limited to protecting confidentiality. Availability must also be protected against unauthorized wireless interference. Protected management frames, monitoring and appropriate security policies can reduce this risk.

6. Fake Wi-Fi Networks at the Republican National Convention, 2016

During the 2016 Republican National Convention, a security experiment established fake open wireless networks near the event venue. Approximately 1,200 users connected within one day, and the experiment demonstrated how easily users could trust unknown network names and expose device or identity information.

Assignment Question: Prepare a Vulnerability Assessment Report evaluating the risks created by open Wi-Fi and fake access points at large public events. Assess SSID trust, automatic reconnection, captive-portal authentication, evil-twin detection, certificate validation, VPN enforcement, and participant-awareness controls.

Answer:

1. Incident Background and Technical Understanding

During the 2016 Republican National Convention, security researchers demonstrated the risks of fake public Wi-Fi networks. Fake access points were created using familiar SSID names to see whether attendees would connect.

Many users connected to these networks, demonstrating that people often trust a familiar Wi-Fi name without verifying its authenticity.

Attack flow:

Fake/Evil-Twin AP → User connects → Attacker-controlled network → Traffic/metadata exposure → Possible credential/data theft

2. Wireless Vulnerabilities

Vulnerability	Severity
Evil-Twin/Rogue AP	High
Trusting familiar SSIDs	High
Automatic Wi-Fi connection	High
Open/unsecured Wi-Fi	High
Weak certificate validation	High
Lack of VPN	High
Poor user awareness	Medium

3. Risk, Impact and Root Cause

Root causes:

- Users trusted familiar SSID names.
- Devices could automatically connect to known networks.
- Users did not verify network authenticity.
- Public Wi-Fi lacked strong authentication.

Impact:

- Exposure of network information.
- Credential theft attempts.

- Phishing and malicious redirection.
- Privacy loss.
- Possible interception of unencrypted traffic.

Overall Risk: HIGH

4. Security Recommendations

- Use WPA2/WPA3 Enterprise for organizational networks.
- Disable automatic connection to unknown Wi-Fi.
- Use VPN on public networks.
- Verify certificates and security warnings.
- Deploy Wireless IDS/IPS.
- Separate guest Wi-Fi from internal networks.
- Provide user awareness training.
- Monitor for rogue access points.

5. Conclusion

The incident demonstrates that an attacker can create a convincing fake Wi-Fi network using a trusted-looking SSID. Users should not treat an SSID name as proof of authenticity. Strong authentication, VPN, monitoring and security awareness can significantly reduce the risk.

7. Wi-Fi Attacks Against Anti-Doping Officials, 2016

According to a United States Department of Justice indictment, close-access teams targeted Wi-Fi networks used by anti-doping officials during events in Rio de Janeiro and Lausanne. Hotel Wi-Fi access was allegedly used to compromise credentials and obtain unauthorized access to sensitive anti-doping and medical information.

Assignment Question: Prepare a Vulnerability Assessment Report for an international sporting organization whose officials frequently use hotel and event Wi-Fi. Evaluate public-network authentication, credential protection, multifactor authentication, device certificates, endpoint security, VPN configuration, travel-security policies, and protection of medical information.

Answer:

1. Incident Background and Technical Understanding

Anti-doping organizations and officials have been targeted by cyberattacks, including attacks involving phishing and compromised network environments. Wireless networks used by officials during travel and events can provide an additional attack surface.

Attackers may attempt to exploit weak public Wi-Fi security or deceive users into connecting to malicious networks.

Attack flow:

Targeted User → Untrusted Wi-Fi/Phishing → Credential Theft → Account Compromise → Sensitive Information Exposure

2. Wireless Vulnerabilities

Vulnerability	Severity
Untrusted public Wi-Fi	High
Rogue access points	High
Phishing	High
Weak authentication	High
Lack of MFA	High
Poor user awareness	Medium
Inadequate monitoring	High

3. Risk, Impact and Root Cause

Root causes:

- Use of insecure networks.
- Social-engineering attacks.
- Weak authentication.
- Insufficient endpoint and network monitoring.

Impact:

- Credential compromise.
- Unauthorized access to organizational systems.
- Exposure of sensitive information.
- Reputation damage.
- Possible disruption of anti-doping operations.

Overall Risk: HIGH

4. Security Recommendations

- Use MFA for important accounts.
- Use VPN on public Wi-Fi.
- Use WPA2/WPA3 Enterprise for organizational networks.

- Deploy wireless monitoring.
- Train employees against phishing and rogue Wi-Fi.
- Disable automatic Wi-Fi connection.
- Keep operating systems and security software updated.
- Apply least-privilege access.

5. Conclusion

Sensitive organizations such as anti-doping agencies should treat public wireless networks as untrusted. Combining VPN, MFA, secure wireless authentication and user awareness can reduce the risk of targeted attacks.

8. Attempted OPCW Wi-Fi Intrusion, 2018

In April 2018, Dutch authorities disrupted an attempted close-access cyber operation against the Organisation for the Prohibition of Chemical Weapons in The Hague. Equipment intended for a Wi-Fi compromise was found in a vehicle parked near the organization's premises.

Assignment Question: Prepare a Vulnerability Assessment Report for the OPCW wireless environment. Assess radio-frequency exposure outside the physical perimeter, enterprise Wi-Fi authentication, 802.1X, EAP certificate validation, rogue-device detection, wireless intrusion prevention, physical surveillance, and network-access control.

Answer:

1. Incident Background and Technical Understanding

The Organisation for the Prohibition of Chemical Weapons (OPCW) reported an attempted cyber intrusion attributed to Russian military intelligence. The attackers reportedly attempted to gain access to the organization's systems while personnel were present at an event in The Hague.

The incident demonstrated the risk of targeted attacks against organizations handling highly sensitive information.

Attack flow:

Targeted Personnel → Nearby Network Access → Attempted Intrusion → Credential/System Access Attempt → Potential Data Exposure

2. Wireless Vulnerabilities

Vulnerability	Severity
Targeted wireless intrusion	Critical
Unauthorized network access	High
Credential theft risk	High

Weak endpoint protection	High
Insufficient network monitoring	High
Social engineering	High

3. Risk, Impact and Root Cause

Root causes:

- Highly targeted cyber activity.
- Attempts to exploit network access near the organization.
- Credential and endpoint security risks.

Impact:

- Confidential information exposure.
- Unauthorized system access.
- Espionage.
- Operational disruption.
- Reputational damage.

Overall Risk: CRITICAL

4. Security Recommendations

- Use WPA3 Enterprise/802.1X.
- Use MFA.
- Implement network segmentation.
- Monitor wireless networks continuously.
- Use endpoint detection and response.
- Restrict access based on device identity.
- Encrypt sensitive information.
- Maintain an incident-response plan.
- Perform regular penetration testing.

5. Conclusion

The OPCW incident demonstrates the importance of protecting organizations against targeted attacks. Strong wireless authentication, segmentation, endpoint security, monitoring and MFA are essential for high-value organizations.

9. Australian Airport and In-Flight Evil-Twin Case, 2024

The Australian Federal Police charged a man who allegedly established fake free Wi-Fi access points that imitated legitimate networks at airports and other locations. The alleged purpose was to capture personal data from users who connected to the fraudulent access points.

Assignment Question: Prepare a Vulnerability Assessment Report for an airport or airline affected by an evil-twin access point. Analyse SSID impersonation, captive-portal authentication, automatic connection, certificate warnings, passenger-data exposure, rogue-access-point detection, staff response procedures, and user-verification methods.

Answer:

1. Incident Background and Technical Understanding

Public Wi-Fi networks in airports and aircraft can be attractive targets for rogue access-point attacks. An attacker can create an Evil-Twin network that resembles the legitimate Wi-Fi service.

Passengers may connect because the fake network has a familiar name.

Attack flow:

Fake Wi-Fi → Passenger connects → Attacker-controlled network → Traffic/credential exposure → Possible account compromise

2. Wireless Vulnerabilities

Vulnerability	Severity
Evil-Twin access point	High
Public Wi-Fi	High
SSID impersonation	High
Automatic connection	High
Lack of VPN	High
User awareness weakness	Medium

3. Risk, Impact and Root Cause

Root causes:

- Users cannot easily distinguish legitimate and fake SSIDs.
- Public networks often provide limited authentication.
- Devices may automatically reconnect.
- Users may perform sensitive activities on public Wi-Fi.

Impact:

- Credential theft.
- Phishing.
- Privacy exposure.
- Malicious redirection.
- Possible session compromise.

Overall Risk: HIGH

4. Security Recommendations

- Verify the official Wi-Fi SSID.
- Disable automatic Wi-Fi connection.
- Use VPN.
- Use HTTPS websites.
- Enable MFA.
- Avoid sensitive transactions on suspicious networks.
- Use WPA3 where supported.
- Deploy rogue-AP detection.
- Provide passenger/user awareness training.

5. Conclusion

Airport and in-flight Wi-Fi should be considered untrusted. Users should verify networks and use VPN and HTTPS, while service providers should implement strong authentication and rogue-access-point monitoring.

10. Network Rail Public Wi-Fi Portal Compromise, 2024

On September 25, 2024, public Wi-Fi services at 19 major United Kingdom railway stations displayed unauthorized offensive content. Reports stated that the Wi-Fi landing page was changed using a legitimate administrator account. The affected services were suspended while the incident was investigated.

Assignment Question: Prepare a Vulnerability Assessment Report examining the authentication and access-control weaknesses that may allow misuse of a legitimate administrator account. Assess privileged-access management, multifactor authentication, captive-portal security, third-party supplier access, logging, change approval, account monitoring, and incident-response procedures.

Answer:

1. Incident Background and Technical Understanding

Public Wi-Fi portals can expose users and service providers to security risks when authentication, session management, or web-application security is weak.

A compromised public Wi-Fi portal could potentially allow attackers to manipulate users, steal credentials or gain unauthorized access to information.

Attack flow:

Public Wi-Fi → Captive Portal → Web Vulnerability → Unauthorized Access → Data/Account Exposure

2. Wireless Vulnerabilities

Vulnerability	Severity
Weak captive-portal security	High
Poor session management	High
Insecure authentication	High
Insufficient HTTPS	High
Web-application vulnerabilities	High
Weak access controls	High
Poor network segmentation	High

3. Risk, Impact and Root Cause

Root causes:

- Weak portal authentication.
- Poor session management.
- Insufficient HTTPS protection.
- Inadequate network segmentation.
- Weak security monitoring.

Impact:

- User credential compromise.
- Unauthorized access.
- Privacy violations.
- Malware/phishing opportunities.
- Service disruption.
- Reputational damage.

Overall Risk: HIGH

4. Security Recommendations

- Enforce HTTPS on the entire portal.
- Use HSTS.
- Secure session cookies using Secure, HttpOnly and SameSite.
- Implement strong authentication.
- Use MFA where appropriate.
- Apply server-side authorization.
- Segment public Wi-Fi from internal systems.
- Deploy IDS/IPS and wireless monitoring.
- Regularly perform vulnerability assessments.
- Patch web servers and applications.

5. Conclusion

Public Wi-Fi portals should be treated as Internet-facing applications and secured accordingly. Strong HTTPS, secure authentication, session protection, network segmentation and continuous monitoring can reduce the risk of compromise.